

SAT 3812: Cyber Security I

Ransomware and Malware

Instructor: Yunlong Xing



Ransomware news

- Ransomware locks up San Francisco public transportation ticket machines
 - <http://arstechnica.com/security/2016/11/san-francisco-muni-hit-by-black-friday-ransomware-attack/>
- Youtube video:
 - <https://www.youtube.com/watch?v=CjyrLNRIgkQ>

What is Ransomware?

- Ransomware is a computer virus that infects computers, encrypts their data, and makes their files inaccessible unless a ransom is paid.
 - A video explaining ransomware (3 min)
 - <https://www.youtube.com/watch?v=FV-HW3NYdF8>
 - Bitcoin is an Internet currency that is unregulated and very difficult to trace. Ransomware hackers prefer it because of the anonymity it provides.

Global Ransomware Damage Costs*

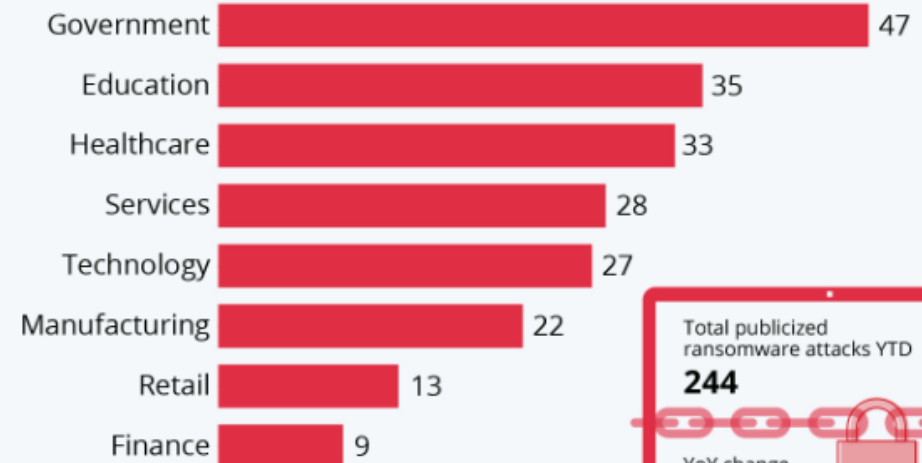
- **2015: \$325 Million**
- **2017: \$5 Billion**
- **2021: \$20 Billion**
- **2024: \$42 Billion**
- **2026: \$71.5 Billion**
- **2028: \$157 Billion**
- **2031: \$265 Billion**



Ransomware is expected to attack a business, consumer, or device every 2 seconds by 2031, up from every 11 seconds in 2021.

The Industries Most Affected by Ransomware

Number of publicized ransomware attacks worldwide by sector in 2021*



Total publicized ransomware attacks YTD

244

YoY change
↑ +25%



* As of Nov 1, 2021
Source: Blackfog

How ransomware works?

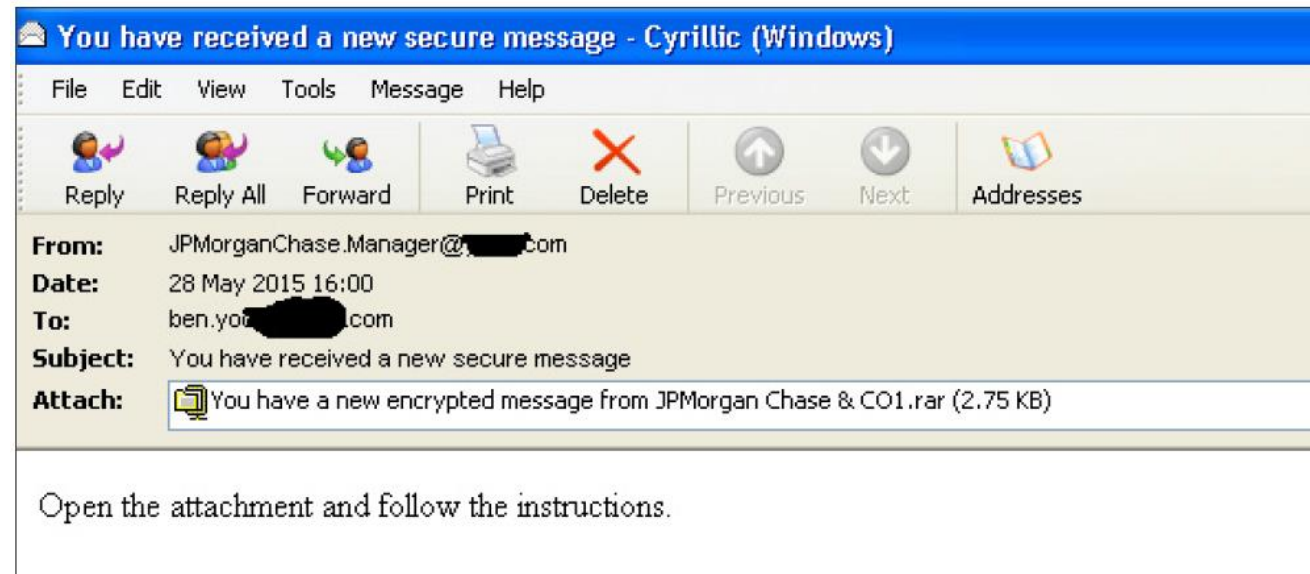
- Take control of a system or device
- Prevent the owner of the controlled device from accessing it, either partially or completely
 - Using cryptography; deleting files; locking...
- Alert the owner that the device has been held for ransom, indicating the method and amount to be paid
- Accept payment from the device owner
 - Bitcoin...
- Return full access to the device owner after payment has been received

Encryption Mechanism

- Most current ransomware use encryption
 - Popular families like cryptolocker and cryptowall use windows crypto libraries
 - Data recovery is often impossible due to modern cryptography
 - Backup your data
 - Don't trust the hacker
 - Using system crypto libraries is a double-edged sword for the attackers
 - Dynamic analysis can catch the use of these libraries

Ransomware Example: CryptoWall

- CryptoWall is a family of file-encrypting Ransomware that first appeared in early 2014.
- Earlier CryptoWall infections were almost always distributed via exploit kits. Recent infection vector is a spam attachment that contains a CHM or RAR file.



Your files are encrypted.

To get the key to decrypt files you have to pay **500 USD**. If payment is not made before **20/07/15 - 19:41** the cost of decrypting files will increase **2 times** and will be **1000 USD/EUR**

Prior to increasing the amount left:

167h 58m 54s

Your system: **Windows XP (x32)**

First connect IP: **[REDACTED]**



Total encrypted **330** files.

Refresh

Payment

FAQ

Decrypt 1 file for FREE

Support

We are present a special software - CryptoWall Decrypter - which is allow to decrypt and return control to all your encrypted files.

How to buy CryptoWall decrypter?



1. You should register Bitcon wallet ([click here for more information with pictures](#))

2. Purchasing Bitcoins - Although it's not yet easy to buy bitcoins, it's getting simpler every day.

Here are our recommendations:

- [LocalBitcoins.com \(WU\)](#) - Buy Bitcoins with Western Union
- [Coincafe.com](#) - Recommended for fast, simple service. Payment Methods: Western Union, Bank of America, Cash by FedEx, Moneygram, Money Order. In NYC: Bitcoin ATM, In Person
- [LocalBitcoins.com](#) - Service allows you to search for people in your community willing to sell bitcoins to you directly.
- [btodirect.eu](#) - THE BEST FOR EUROPE
- [coinmr.com](#) - Another fast way to buy bitcoins
- [bitquick.co](#) - Buy Bitcoins Instantly for Cash
- [How To Buy Bitcoins](#) - An international directory of bitcoin exchanges.
- [Cash Into Coins](#) - Bitcoin for cash.
- [CoinJar](#) - CoinJar allows direct bitcoin purchases on their site.
- [anxpro.com](#)
- [bittylicious.com](#)
- [ZipZap](#) - ZipZap is a global cash payment network enabling consumers to pay for digital currency.

3. Send 1.79 BTC to Bitcoin address:

[REDACTED]

Ransomware Attack Mitigation Practices

- Most important: backup and training
- 1. Use a boundary defense that can identify malware based on its behavior and not just use signatures of known threats.
- 2. Lock down personal computers and other devices so they are not vulnerable to exploits from ransomware.
- 3. Lock down IT infrastructure so that ransomware cannot get into critical systems.

Future trends on ransomware

- Most vulnerable systems: windows & Android
 - but no system is immune, including Linux and Mac
- Customized ransomware
 - Bypass malware monitoring system!!!
- Should we blame Bitcoin for ransomware explosion?

Hackers have a sense of humor?

Ransomware runs a referral program

Restoring your files - The fast and easy way To get your files fast, please transfer 1.0 Bitcoin to our wallet address 1LEiPgvh6S9VEXWV2dZTytSRd7e9B1bWt3. When we will get the money, we will immediately give you your private decryption key. Payment should be confirmed in about 2 hours after payment made.	Restoring your files - The nasty way Send the link below to other people, if two or more people will install this file and pay, we will decrypt your files for free. https://3hnuhydu4pd247qb.onion.to/r/0e72bfe849c71dec4a867fe60c78ffa5
---	---

A ransomware called Popcorn Time gives you two options to unlock files:

1. Pay a ransom of around \$US800 within seven days
2. Infect two other users by sending them a malicious link to click on

Would you spread ransomware to people you don't like just to unlock your own encrypted files?

Ransomware may not honor its promise!

- \$247,000 KillDisk ransomware demands a fortune, forgets to unlock files
- The malware asks for 222 Bitcoin but will not honor promises to decrypt files after payment is made.



We are so sorry, but the encryption
of your data has been successfully completed,
so you can lose your data or
pay 222 btc to 1Q94RXqr5WzyNh9Jn3YLDGeBoJhxJBigcF
with blockchain.info
contact e-mail: vuyrk568gou@lelantos.org

Want to do research on Ransomware?

- <https://github.com/ytisf/theZoo>
- Source code and binary for many malware and ransomware
- Write your own simple ransomware!
 - On dark web, the Shark (Atom now) Ransomware Project allows you to create your own Customized Ransomware

Other Malwares:
virus, worms, spyware, adware ...

Worms

- Replicating program that propagates over network
 - using email, remote exec, remote login
- has phases like a virus:
 - dormant, propagation, triggering, execution
 - propagation phase: searches for other systems, connects to it, copies self to it and runs
- may disguise itself as a system process

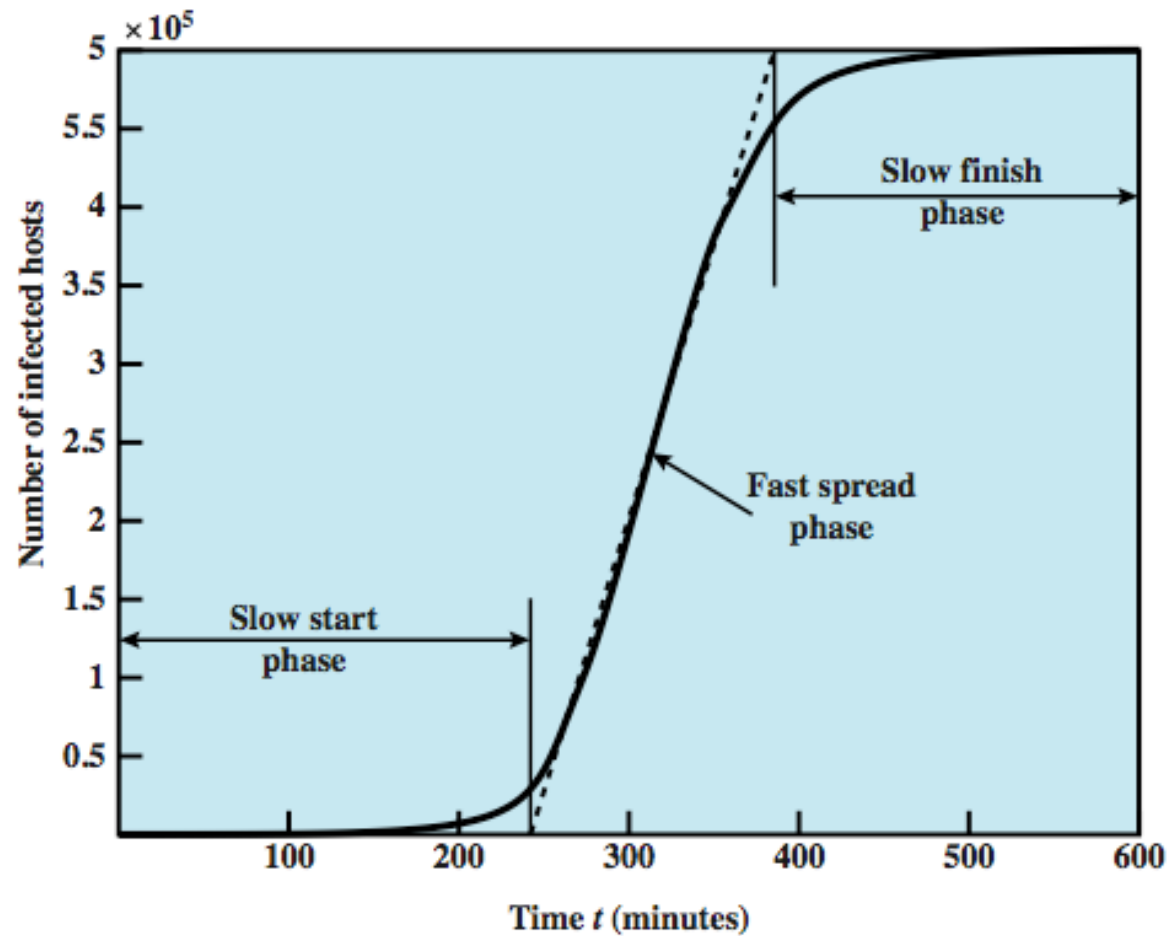
Robert Morris Wrote The Internet Worm in 1988

**The
Internet
WORM**



- **1989 - Indicted under the Computer Fraud and Abuse Act of 1986 on July 26, 1989 - the first person to be indicted under this Act.**
- **1990 - Convicted and sentenced to three years of probation, 400 hours of community service, a fine of \$10,050 and the cost of his supervision.**

Worm Propagation Model



More Worms

- Code Red
- Nimda
- Blaster
- SQL Slammer
- Mydoom
- More info at:
 - http://en.wikipedia.org/wiki/Timeline_of_notable_computer_viruses_and_worms

SQL Slammer Worm

- Exploited another buffer overflow
 - Took a single 376-byte UDP packet
 - UDP connectionless -> spread quickly
 - Infected 75,000, 90% w/in 10 minutes
- Attacked Microsoft SQL Server DB App
- Disabled server, scanned random IPs to infect
- Impact
 - Excessive traffic due to the worm propagating caused outages in 13,000 BoA ATMs
 - Airlines were cancelled & delayed

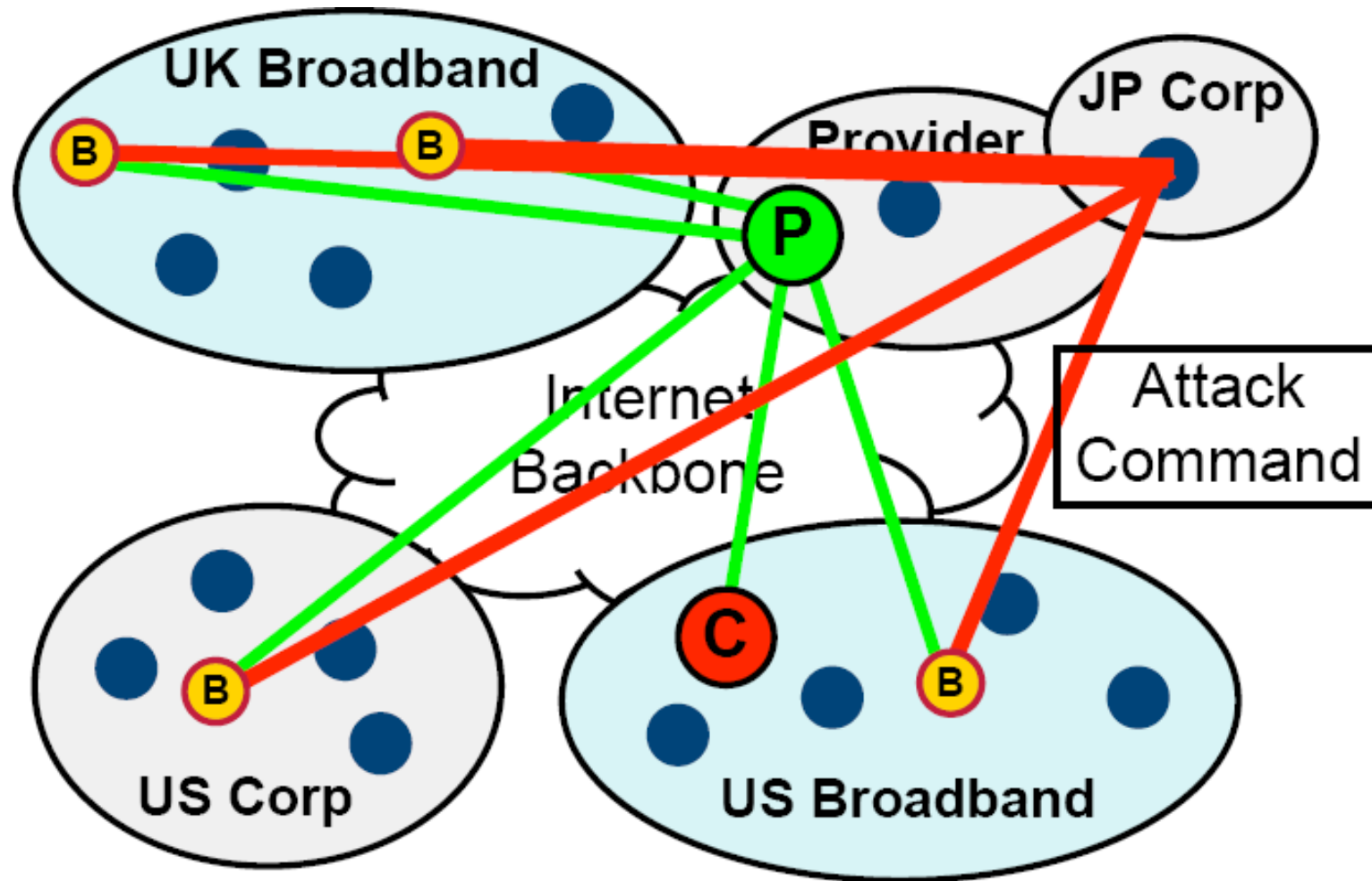
Spyware and Adware

- What is Spyware?
 - Software application that monitors a user's computing habits and personal information,
 - and sends this information to third parties without the user's authorization or knowledge
 - Examples: key loggers, event loggers, cookies, screen captures or a combination of these forms
- What is Adware?
 - Software application that displays advertising banners while the program is running

Rootkits

- set of programs installed for admin access
- malicious and stealthy changes to host O/S
- may hide its existence
 - subverting report mechanisms on processes, files, registry entries etc
- may be:
 - persistent or memory-based
 - user or kernel mode
- installed by user via Trojan or intruder on system

The Botnet



Centralized control of bots

Attack commands be push (i.e. IRC) or pull (i.e. HTTP)

IoT Malware

- Mirai Botnet Linked to Dyn DNS DDoS Attacks in 2016
- About half-million low-price webcams made by a company are involved in the DDoS attack.
- Mirai is a virus on Internet-of-Things (IoT)!
 - Great research topic!
 - Source code is available now
 - <https://github.com/jgamblin/Mirai-Source-Code/tree/6a5941be681b839eeff8ece1de8b245bcd5ffb02>

Mirai botnet



Hajime, a botnet malware

- <https://security.rapiditynetworks.com/publications/2016-10-16/hajime.pdf>
- <https://securelist.com/hajime-the-mysterious-evolving-botnet/78160/>
- No attacking code, just propagate itself.
 - Hajime gains the root access to your webcam
- Fighting between malwares
 - If a malware gains the root access, it will block the door for other malwares
 - A new malware may try to kick out the old one
 - Your webcam, their battleground

2 minutes to hack an IoT camera

- 2016: IoT camera turned into a zombie in under two minutes
 - <https://nakedsecurity.sophos.com/2016/11/30/iot-camera-turned-into-a-zombie-in-under-two-minutes/>
- 2017: It Still Takes 2 Minutes to Have Vulnerable IoT Devices Compromised Online
 - <https://www.bleepingcomputer.com/news/security/it-still-takes-2-minutes-to-have-vulnerable-iot-devices-compromised-online/>

Common IoT vulnerabilities

- Weak default password
- Users didn't change default password
- Hard-coded password within device
- No update on device firmware

More about Wannacry

- Microsoft vulnerability + Bitcoin + encryption
- Is network isolation strong enough to protect your network?
 - Intranet vs Internet
 - Physical isolation is vulnerable
 - USB drive, smart phones, emails, old software...
 - Industrial control system security relies on network isolation and obscurity

An on-going battle against all
kinds of Malwares